

中华人民共和国通信行业标准

YD/T ××××—××××

网络安全防护同规划同建设同运行实施要求

Three synchronization requirements for network security protection

(报批稿)

××××-××-××发布

××××-××-××实施

中华人民共和国工业和信息化部 发布

目 次

前 言.....	II
1 范围.....	1
2 规范性引用文件.....	1
3 术语、定义和缩略语.....	1
3.1 术语和定义.....	1
3.2 缩略语.....	1
4 网络安全防护同规划、同建设、同运行实施概述.....	2
4.1 网络安全防护同规划、同建设、同运行基本原则.....	2
4.2 网络安全防护同规划、同建设、同运行实施对象.....	2
4.3 网络安全防护同规划、同建设、同运行实施内容.....	2
4.4 网络安全防护同规划、同建设、同运行报告的报备要求.....	3
4.5 网络安全防护同规划、同建设、同运行管理要求.....	3
5 网络安全防护同规划、同建设、同运行实施要求.....	4
5.1 同步规划要求.....	4
5.2 同步建设要求.....	6
5.3 同步运行要求.....	8

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院，中国科学院信息工程研究所，重庆贝特计算机系统工程有
限公司。

本文件主要起草人：孟楠，崔涛，赵相楠，贺倩，张鹏，安继森，方全，郭发敏，李佳曦，鲁冬雪，
刘潮歌，周海龙，王成刚。

网络安全防护同规划同建设同运行实施要求

1 范围

本文件规定了网络安全防护的同规划、同建设、同运行实施要求，具体包括：安全技术措施的同步规划、同步建设、同步运行。

本文件适用于通信网络运行单位新建、改建、扩建的网络工程项目。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

YD/T 1730 电信网和互联网安全风险评估实施指南

3 术语和定义

下列术语和定义适用于本文件。

3.1.1

网络安全防护同规划、同建设、同运行实施要求

three synchronization requirements for network security protection

安全技术措施的同步规划、同步建设、同步运行。

3.1.2

网络安全防护 network security protection

保障电信和互联网及相关系统的网络安全和信息安全、防范违法犯罪的技术设施和技术方法。

4 网络安全防护同规划、同建设、同运行实施概述

4.1 网络安全防护同规划、同建设、同运行基本原则

实施网络安全防护同规划、同建设、同运行的核心是安全技术措施的同步规划、同步建设、同步运行。网络安全防护同规划、同建设、同运行实施过程中应遵循以下基本原则：

a) 自主保护原则

电信和互联网及相关系统的运营、使用单位按照国家相关法规和标准，自行组织实施网络安全防护同规划、同建设、同运行工作。

b) 重点保护原则

电信和互联网及相关系统的运营、使用单位，按照系统的不同安全保护等级，落实不同强度的网络安全防护同规划、同建设、同运行要求。

c) 同步建设原则

电信和互联网及相关系统在新建、改建、扩建时，运营、使用单位应投入一定的资源，开展安全技术措施的同步规划、同步建设、同步运行。

d) 动态调整原则

要跟踪电信和互联网及相关系统的变化情况，调整安全保护措施。

4.2 网络安全防护同规划、同建设、同运行实施对象

通信网络运行单位新建、改建（扩建）、已建的电信网和互联网及相关系统应实施网络安全三同步。

新建的电信网和互联网及相关系统应进行安全技术措施的同步规划、同步建设、同步运行。

改建（扩建）的电信网和互联网及相关系统，改建（扩建）部分应进行安全技术措施的同步规划、同步建设、同步运行。

已建的电信网和互联网及相关系统，则应在生命周期中的运行阶段补足安全技术措施的同步规划、同步建设，进行安全技术措施的同步运行。

4.3 网络安全防护同规划、同建设、同运行实施内容

4.3.1 网络安全防护同规划、同建设、同运行实施流程

在涉及重大变更和局部调整时，网络安全防护同规划、同建设、同运行的实施流程如图1所示。

4.3.2 安全技术措施同步规划

安全技术措施同规划应至少包括安全需求分析、安全总体设计、安全建设规划等几个主要活动。通信网络运行单位通过安全需求分析判断网络安全保护现状与安全要求之间的差距，确定初步的安全需求，通过分析业务风险确定进一步的安全需求；然后根据网络的实际情况，设计出合理的、满足安全等级保护要求的安全总体方案，并制定出安全建设的方案，以指导后续的网络安全建设工程实施。

4.3.3 安全技术措施同步建设

安全技术措施同建设应至少包括安全方案详细设计、安全详细设计方案的实施、安全检测等几个主要活动。通信网络运行单位通过安全方案详细设计，将安全技术措施同步规划的安全总体方案和安全建设方案具体落实到网络中，最终提交满足安全需求的网络、系统以及配套的安全技术和管理体系。网络和业务运营商应在网络实际运行之前对其安全等级保护工作的实施情况进行安全检测，确保其达到安全防护要求。

4.3.4 安全技术措施同步运行

安全技术措施同运行应至少包括以下活动：通信网络运行单位通过运行管理和控制、变更管理和控制、安全状态监控，对发生的安全事件及时响应，确保电信网和互联网及相关系统的安全技术措施正常运行；通过安全检查和持续改进不断跟踪电信网和互联网及相关系统的变化，并依据变化调整其安全等级和安全措施；通过安全检测，确保电信网和互联网及相关系统满足相应安全等级的要求。

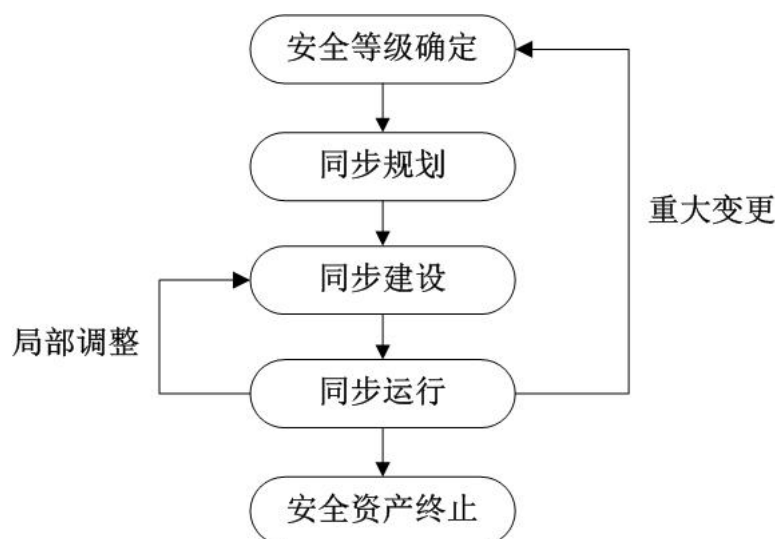


图 1 网络安全防护同规划、同建设、同运行实施的流程

4.4 网络安全防护同规划、同建设、同运行报告的报备要求

通信网络运行单位应在网络安全防护同规划、同建设、同运行报告完成后三十个工作日内，将评估报告通过书面或信息化系统向对本企业颁发电信业务经营许可证或者进行电信业务备案的行业主管部门备案。

4.5 网络安全防护同规划、同建设、同运行管理要求

通信网络运行单位应针对新建、改建（扩建）、已建的电信网和互联网及相关系统的网络安全防护同规划、同建设、同运行建立完善的制度流程以及监督管理机制，对系统建设运行的各个阶段进行系统

化管理。定期对网络安全防护同规划、同建设、同运行落地执行情况进行整理、汇总、上报。网络安全防护同规划、同建设、同运行实施要求

4.6 同步规划要求

4.6.1 安全需求分析

实施网络安全同步规划时应进行安全需求分析，安全需求分析应包括以下内容：

- a) 首先应确定具体进行安全等级保护工作的对象，包括整体对象（如机房、办公环境、网络等）和具体对象（如边界设备、网关设备、服务器设备、工作站、应用系统等）；获得其技术和管理方面的信息，技术方面包括业务/应用、网络、设备、物理环境等信息，管理方面包括安全管理机构、安全管理制度、人员管理、网络建设和运维管理等信息。
- b) 将安全等级保护对象对应的安全防护要求中安全等级保护管理和技术方面的安全指标作为依据，将安全等级保护对象的安全现状与指标进行逐一对比，通过观察现场、询问人员、查询资料、检查记录等方式进行安全管理方面的比较，通过观察现场、询问人员、查询资料、检查记录、检查配置、技术测试、渗透测试等方式进行安全技术方面的比较，判断安全管理和技术的各个方面与等级保护要求中的基本安全要求之间的差距，给出初步的安全需求。
- c) 在确定初步安全需求的基础上，应按照 YD/T 1730 对安全等级保护对象进行安全风险评估，即通过分析安全等级保护对象中的重要资产的资产价值、存在的脆弱性、面临的威胁、以及已经采取的安全措施，判断安全等级保护对象可能存在的安全风险，在初步安全需求的基础上，制定出额外的安全需求。
- d) 对于安全等级保护对象中的关键系统和数据，为确保在灾难发生后网络能够尽快恢复和继续运行，应制定出有效的灾难备份及恢复的额外需求。
- e) 在制定额外安全需求时，应明确国家及企业的安全目标，借鉴以往建设的类似或相关的电信网和互联网及相关系统的安全需求，并且确保安全需求与其它相关标准或规范对其的安全需求不发生冲突。
- f) 总结安全指标对比结果和风险评估的结果，获得安全等级保护对象安全现状的汇总、与安全防护要求中安全等级保护要求的差距汇总和额外的安全需求的汇总，最终形成安全需求分析报告，报告中应包括安全管理状况和安全技术状况。

4.6.2 安全总体设计

实施网络安全同步规划时应进行安全总体设计，安全总体设计应包括以下内容：

a) 对电信网和互联网及相关系统的构成内容进行抽象处理，提取共性形成模型和要素，如应用程序、服务器设备、构成网络的网络设备等；根据安全防护要求中的等级保护相关要求和安全需求分析报告，针对模型要素提出需要实现的安全措施，包括安全技术方面的措施和安全管理方面的措施，以指导安全等级保护工作的具体实现。

b) 将安全总体设计工作的结果文档化，形成满足其所属的安全等级要求的安全总体方案，安全总体方案中包括总体安全策略、技术措施和管理措施等。

4.6.3 安全建设规划

实施网络安全同步规划时应进行安全建设规划，安全建设规划应包括以下内容：

a) 安全建设规划是依据电信网和互联网及相关系统安全总体方案、网络和业务运营商当前面临的机遇和挑战以及安全建设时间和经费投入状况，结合安全需求分析结果，同时考虑到网络和业务运营商的中长期发展规划，提出分阶段的安全建设目标、设计建设内容，形成安全建设方案，重点是形成近期可行的安全建设方案。安全建设方案中包括安全技术建设规划和安全管理建设规划。

b) 将安全建设规划的结果文档化，形成分阶段的安全建设方案，安全建设方案中包括总体安全建设规划、技术体系建设规划和管理体系建设规划等。

4.6.4 文档输出要求

网络安全同步规划工作应至少输出以下文档：

- a) 安全需求分析报告。报告中应包括安全管理措施和安全技术措施。
- b) 安全预定级报告。报告中应包括电信网和互联网及相关系统的预定级内容。
- c) 安全总体方案。安全总体方案中应包括总体安全策略、技术措施和管理措施等。
- d) 安全建设方案。安全建设方案中应包括安全技术建设规划和安全管理建设规划。

4.6.5 评审验收要求

应对网络安全同步规划的的实施情况进行评审验收，评审验收要求如下：

- a) 应由第三方机构对同步规划的实施情况进行评审验收，该第三方机构应属于具备相应安全资质（通过有关行业协会网络安全服务能力评定）的非利益相关方。
- b) 应评审文档：安全需求分析报告、安全总体方案、安全建设方案。确保安全措施同步建设的相关文档满足其所属安全等级要求。

- c) 在同步规划工作的评审验收通过后，应由第三方出具同步规划工作的评审验收报告；否则，须重新对同步规划工作进行完善修正，直到通过第三方机构的评审。

4.7 同步建设要求

4.7.1 安全方案详细设计

实施网络安全同步建设时应进行安全方案详细设计，详细设计要求如下：

- a) 应根据建设目标和建设内容，将安全总体方案和安全建设方案本阶段中的要求落实到产品功能或物理形态上，提出指定的产品或组件及其具体规范，明确安全产品的功能和性能要求设计，网络或设备的部署方案。
- b) 应根据当前安全管理和技术需要提出与安全总体方案中管理部分相适应的本期安全实施内容，以保证安全技术建设的同时，安全管理的同步建设。安全管理设计的内容主要考虑安全管理机构和人员的配套、安全管理制度的配套、人员安全管理技能的配套等。
- c) 应将安全等级保护技术实施内容和安全等级保护管理实施内容的设计汇总，同时考虑工时和经费，最后形成安全详细设计方案，指导具体的安全实施。

4.7.2 安全详细设计方案实施

应在安全详细设计方案的指导下，进行安全等级保护管理实施和安全等级保护技术实施，技术实施要求如下：

- a) 安全等级保护管理实施主要是建立与电信网和互联网及相关系统安全技术和安全运行相适应的安全管理机制，包括建立配套的安全管理机构和人员，建立配套的安全管理制度和操作规程，进行人员的安全技能培训等，并且在安全实施过程中，对工程的质量、进度、文档和变更等方面的工作进行监管。
- b) 安全等级保护技术实施主要是保证按照安全详细设计方案实现各项安全技术措施，包括网络安全审查、安全产品采购、安全控制开发、安全控制集成、测试与验收等主要活动环节。安全产品采购是按照安全详细设计方案中对于产品的具体指标要求进行产品采购，根据产品或产品组合实现的功能满足安全设计要求的情况来选购所需的安全产品；安全控制开发是对于一些不能通过采购现有安全产品来实现的安全措施和安全功能，通过专门的设计、开发来实现；安全控制集成依据安全详细设计方案，将安全产品、软件平台和开发的安全控制模块与各种应用综合、整合成为一个系统，最后通过测试与验收检验网

络/系统是否严格按照安全详细设计方案进行建设，是否实现了设计的功能和性能，从而确保安全技术措施的有效性。

c) 在安全实施完成后，应建成满足安全需求并通过测试验收的电信网和互联网及相关系统，提交验收报告，内容包括安全产品清单、验收过程及结果等，提交配套的安全管理规章制度。

4.7.3 安全检测

实施网络安全防护同步建设时应开展安全检测工作，安全检测要求如下：

a) 应依据本系列标准中的安全防护要求和安全防护检测要求，对电信网和互联网及相关系统的安全保护管理制度和技术措施的落实情况、以及安全现状的达标情况进行检查，判断其安全保护措施是否符合相应安全等级的基本保护要求。

b) 安全检测完成后，检测方应根据实际检测情况形成检测报告。应对报告中发现的问题及应对措施闭环管理，确保在系统全生命周期内得到有效管控。

4.7.4 文档输出要求

网络安全防护同步建设工作应至少输出以下文档：

a) 安全方案详细设计报告。报告中应包括安全等级保护技术实施内容和安全等级保护管理实施内容。

b) 安全详细设计方案实施验收报告。内容包括安全产品清单、验收过程及结果等，以及配套的安全管理规章制度

c) 安全检测报告。内容应包括对电信网和互联网及相关系统的安全保护管理制度和技术措施的落实情况、以及安全现状的达标情况。

4.7.5 评审验收要求

应对网络安全同步建设的的实施情况进行评审验收，评审验收要求如下：

a) 应由第三方机构对同步建设的实施情况进行评审验收，该第三方机构应属于具备相应安全资质（通过有关行业协会网络安全服务能力评定）的非利益相关方。

b) 应评审文档：安全方案详细设计报告、安全详细设计方案实施验收报告、安全检测报告。确保安全措施同步建设的相关文档满足其所属安全等级要求。

c) 应通过测试与验收检验网络/系统是否严格按照安全详细设计方案进行建设，是否实现了设计的功能和性能，从而确保安全技术措施的有效性。

d) 在同步建设工作的测试验收通过后,应由第三方出具同步规划工作的评审验收报告;否则,须重新对同步规划工作进行完善修正,直到通过第三方机构的评审。

4.8 同步运行要求

4.8.1 运行管理和控制

实施网络安全防护同步运行时应进行运行管理和控制,运行管理和控制的要求如下:

- a) 应通过对运行管理活动相关的角色划分,并授予相应的管理权限,来确定安全运行管理的具体人员和职责;
- b) 应通过制定运行管理操作规程,确定运行管理人员的操作目的、操作内容、操作时间和地点、操作方法和流程等,并进行操作过程记录,确保对操作过程进行控制。实现网站数据监测功能的监控保护程序的异常关闭;
- c) 应通过运行管理的职责确定形成运行管理人员角色和职责表,通过对运行管理过程进行控制形成运行管理操作规程,以及操作过程记录文件。
- d) 运行维护人员应对系统建设、验收过程中发现的残留安全风险及应对措施进行了解 and 掌握,在维护过程中确保其有效性。

4.8.2 变更管理和控制

实施网络安全防护同步运行时应进行变更管理和控制,变更管理和控制如下:

- a) 应通过对变更需求和变更影响的分析,制定变更方案;
- b) 应确保变更实施过程受到控制,审核变更内容,对各项变化内容进行记录,保证变更对正在运行的电信网和互联网及相关系统的影响最小;
- c) 应根据变更方案和变更实施过程的各项活动,形成变更报告。

4.8.3 安全状态监控

实施网络安全防护同步运行时应进行安全状态监控,安全状态监控要求如下:

- a) 应根据监控的必要性和可行性、监控的开销和成本等因素,确定监控对象,形成监控对象列表,根据监控对象的特点、监控管理的具体要求、监控工具的功能、性能特点等,选择合适的监控工具;
- b) 应通过监控工具对监控对象的安全状态进行监控,收集来自监控对象各类状态信息,可能包括网络流量、日志信息、安全报警和性能状况等,或者是来自外部环境的安全标准和法律法规的变更信息。

c) 应对安全状态信息进行分析,及时发现安全事件或安全变更需求,并对其影响程度和范围进行分析,形成安全状态分析报告。

4.8.4 安全事件处置和应急预案

实施网络安全防护同步运行时应对安全事件进行应急响应和处置,应急响应和处置要求如下:

a) 应根据安全事件相关标准中规定的安全事件分级原则和划分结果,结合自身具体的实际情况,通过预测、评估和分析事件对电信网和互联网及相关系统的破坏程度,所造成后果严重程度,将安全事件进行等级划分。

b) 应针对不同等级、不同优先级的安全事件制定相应的应急预案程序,说明应急预案启动的条件,发生安全事件后要采取的流程和措施等,充分体现自主保护的原则,保障电信网和互联网及相关系统的持续运行。

c) 根据安全状态分析报告分析可能的安全事件,如果明确为安全事件的,则需采取适当的方法进行处置,对安全事件的等级和影响程度等进行分析,确定是否启动应急预案。

d) 对安全事件处置过程进行总结,形成安全事件处置报告,报告中包括安全事件的类型、等级和采取的措施等,并输出制定的应急预案。

4.8.5 安全状态检查和持续改进

实施网络安全防护同步运行时应进行安全状态检查并不断改进,安全状态检测要求如下:

a) 应定期对电信网和互联网及相关系统进行安全状态检查。通过安全状态检查,为电信网和互联网及相关系统的持续改进过程提供依据和建议,确保电信网和互联网及相关系统的安全保护能力满足其相应等级的基本安全要求和自身特殊的安全需求;

b) 应通过询问、检查和测试等多种手段进行安全状况检查,记录各种检查活动的结果数据,分析安全措施的有效性、安全事件产生的可能性,并可根据检查结果提出对电信网和互联网及相关系统的改进需求和建议等;

c) 应根据安全状态检查结果对电信网和互联网及相关系统进行持续改进,确定安全改进的策略,确保电信网和互联网及相关系统的安全保护能力满足相应等级安全要求和自身特殊的安全需求,确保安全等级保护工作的有效性;

d) 应在进行安全状态检查后,形成安全检查报告;制定安全改进方案,并根据验收结果形成验收报告。

4.8.6 安全检测

实施网络安全防护同步运行时应开展安全检测工作，安全检测工作要求如下：

- a) 应遵照安全等级保护相关标准对已经完成安全等级保护建设、并投入运行的电信网和互联网及相关系统进行安全检测，判断其安全保护措施是否符合相应安全等级的基本保护要求。
- b) 安全检测完成后，检测方应根据实际检测情况形成检测报告。

4.8.7 文档输出要求

网络安全防护同步运行工作应至少输出以下文档：

- a) 运行管理人员角色和职责表、运行管理操作规程、操作过程记录文件。
- b) 变更报告。
- c) 安全状态分析报告。
- d) 应急预案、安全事件处置报告。
- e) 安全检查报告、安全改进方案、验收报告。
- f) 安全检测报告。
- g) 定级备案报告。

4.8.8 评审验收要求

应对网络安全同步运行的实施情况进行评审验收，评审验收的要求如下：

- a) 应由第三方机构对同步运行的实施情况进行评审验收，该第三方机构应属于具备相应安全资质（通过有关行业协会网络安全服务能力评定）的非利益相关方。
 - b) 应评审文档：安全方案详细设计报告、安全详细设计方案实施验收报告、安全检测报告。确保网络安全防护同步运行的相关文档满足其所属安全等级要求。
 - c) 应通过测试与验收检验网络/系统是否严格按照同步运行相关文档的要求进行运行，从而确保网络/系统具有支持业务稳定、持续运行的性能。
 - d) 在同步运行工作的评审验收通过后，应由第三方出具同步规划工作的评审验收报告；否则，须重新对同步运行工作进行完善修正，直到通过第三方机构的评审。
-